

Actividad 08: Road to Hall Of Fame

Laboratorio: File path traversal, traversal sequences blocked with absolute path bypass

Asignatura: Seguridad Informática

Realizado por el alumno: Manuel Darío Trejo Salazar

Herramienta utilizada: Burp Suite Community Edition

1.- Nombre del laboratorio

File path traversal, traversal sequences blocked with absolute path bypass

URL del laboratorio:

<https://portswigger.net/web-security/file-path-traversal/lab-absolute-path-bypass>

The screenshot shows the PortSwigger lab interface. At the top, the title 'Lab: File path traversal, traversal sequences blocked with absolute path bypass' is displayed in a light blue font. Below the title, there is a 'PRACTITIONER' badge and a 'LAB' button with a checkmark and the text 'Solved'. A red circular icon with a white arrow is in the top right corner. The main text describes the lab: 'This lab contains a path traversal vulnerability in the display of product images. The application blocks traversal sequences but treats the supplied filename as being relative to a default working directory. To solve the lab, retrieve the contents of the `/etc/passwd` file.' Below this text is an orange button with a flask icon and the text 'ACCESS THE LAB'. At the bottom, there are two dark blue buttons: 'Solution' and 'Community solutions', both with a light blue icon and a downward arrow.

2.- Nivel

Practitioner (practicante).

Este laboratorio presenta un mecanismo de defensa básico (bloqueo de secuencias de recorrido relativo) que el atacante debe evadir usando una ruta absoluta directa hacia el archivo objetivo.

3.- Tipo de explotación

File Path Traversal (también conocido como Directory Traversal o recorrido de directorios), clasificado dentro de las vulnerabilidades de lectura arbitraria de archivos (Arbitrary File Read).

La vulnerabilidad ocurre cuando la aplicación web intenta validar la entrada del usuario bloqueando secuencias típicas de salto de directorio (como ../ o ..\), pero falla al no comprobar si el valor proporcionado es una ruta absoluta desde la raíz del sistema de archivos.

Al existir esta validación incompleta, el atacante no puede usar saltos relativos, pero puede enviar directamente:

GET /image?filename=/etc/passwd

El servidor recibe esta ruta absoluta y, al no detectar los patrones ../ bloqueados, la procesa de forma directa, saltándose el directorio de trabajo previsto para las imágenes y mostrando el contenido del archivo del sistema operativo.

Consecuencias: Lectura de archivos sensibles, obtención de credenciales del sistema, conocimiento de la estructura interna del servidor y posible escalada a otras vulnerabilidades (como LFI).

4. Objetivo del laboratorio

Demostrar la explotación de una vulnerabilidad de File Path Traversal evadiendo un filtro de seguridad que bloquea secuencias de recorrido (../). Esto se logra enviando una ruta absoluta a través del parámetro filename de la petición HTTP que carga las imágenes de los productos, con el fin de leer el contenido del archivo /etc/passwd del servidor y obtener la confirmación de "Lab solved" en la Web Security Academy.

5. Explicación técnica de la vulnerabilidad

La tienda en línea carga las imágenes de los productos a través de una petición HTTP GET con un parámetro filename:

GET /image?filename=71.jpg HTTP/2

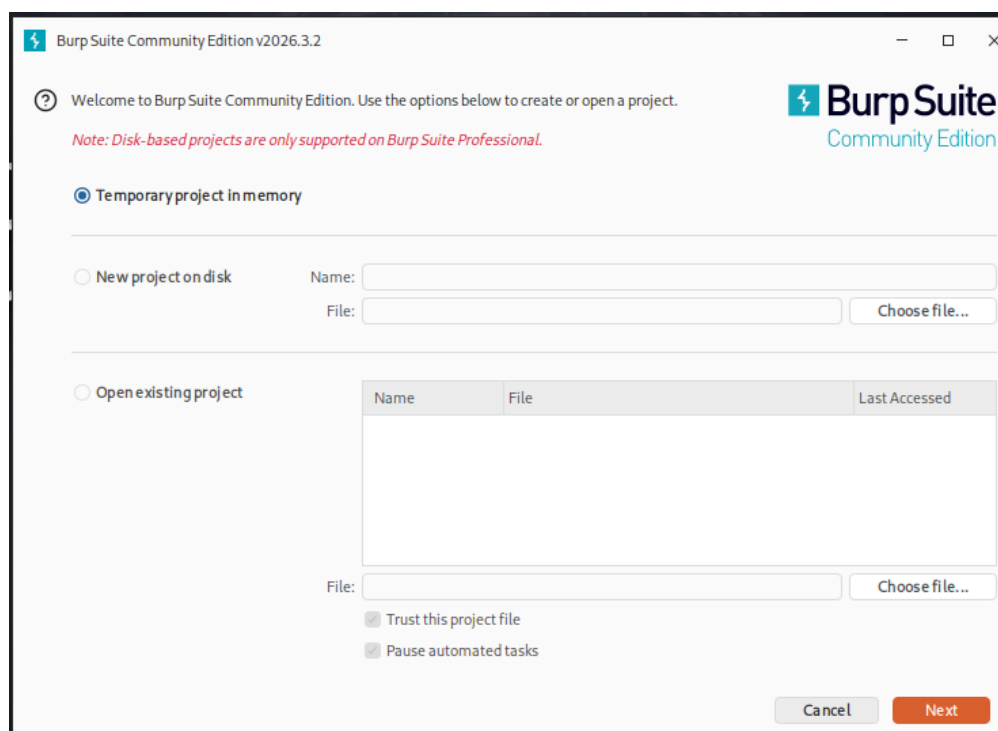
La aplicación implementa una medida de seguridad que busca y bloquea o elimina explícitamente secuencias de recorrido relativas (como ../).

Sin embargo, el servidor asume que el nombre de archivo suministrado siempre será relativo a un directorio de trabajo predeterminado (por ejemplo, /var/www/images/). La falla técnica radica en que la función backend (API del sistema de archivos) que abre el recurso permite el uso de rutas absolutas.

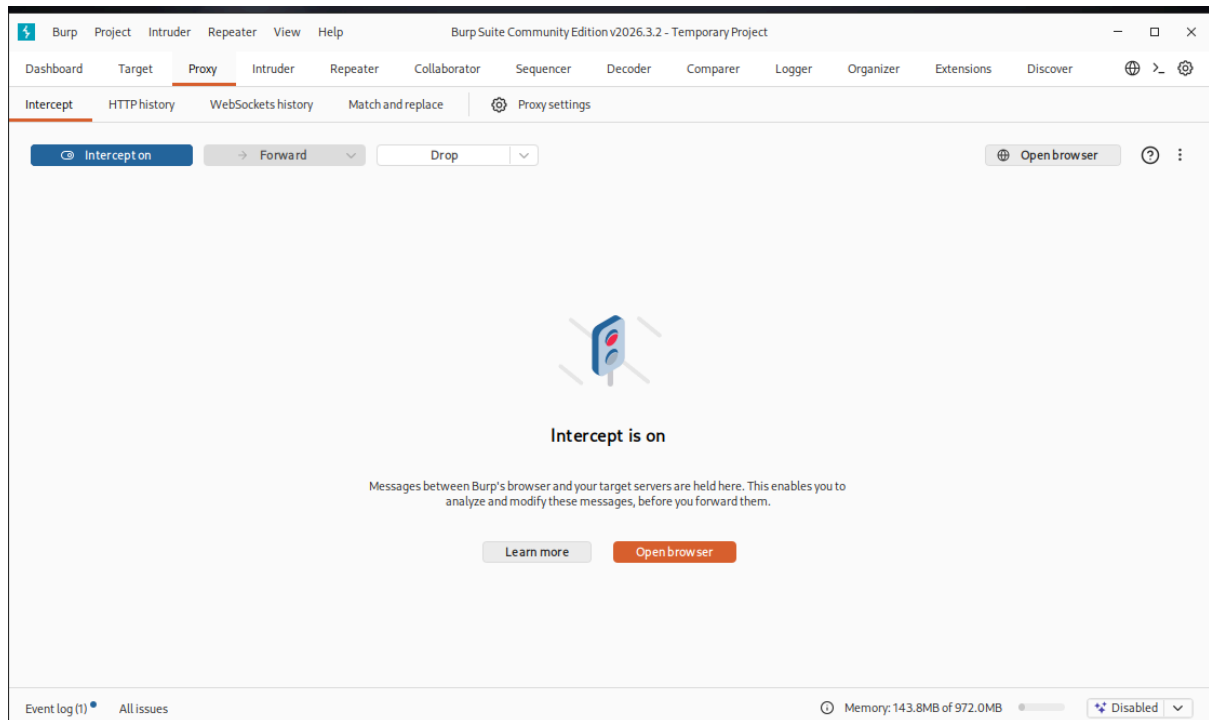
Al enviar directamente la ruta absoluta /etc/passwd, el filtro de seguridad nunca se activa porque la entrada no contiene las secuencias prohibidas ../. El sistema de archivos evalúa la entrada partiendo de la raíz (/) e ignora por completo el directorio base predeterminado de la aplicación. Esto constituye un fallo clásico de validación de entrada por depender exclusivamente de una lista negra (blacklist) incompleta.

6. Procedimiento paso a paso

Se inicia Burp Suite Community Edition desde la máquina virtual, seleccionando en las configuraciones iniciales, Temporary project in memory y posteriormente Use Burp defaults.



Con Burp abierto en la pestaña Proxy > Intercept, se abre el navegador integrado y se accede a la URL del laboratorio proporcionada por PortSwigger.



En Burp Suite se desactiva temporalmente el interceptor ("Intercept is off") para permitir la carga completa de la página. Se navega a la página de un producto (clic en "View details"), lo que dispara la petición que carga la imagen del producto.

WE LIKE TO SHOP



Paddling Pool Shoes

★★★★★ \$30.87

[View details](#)



Cheshire Cat Grin

★★★☆☆ \$91.23

[View details](#)



Snow Delivered To Your Door

★★★★★ \$0.69

[View details](#)



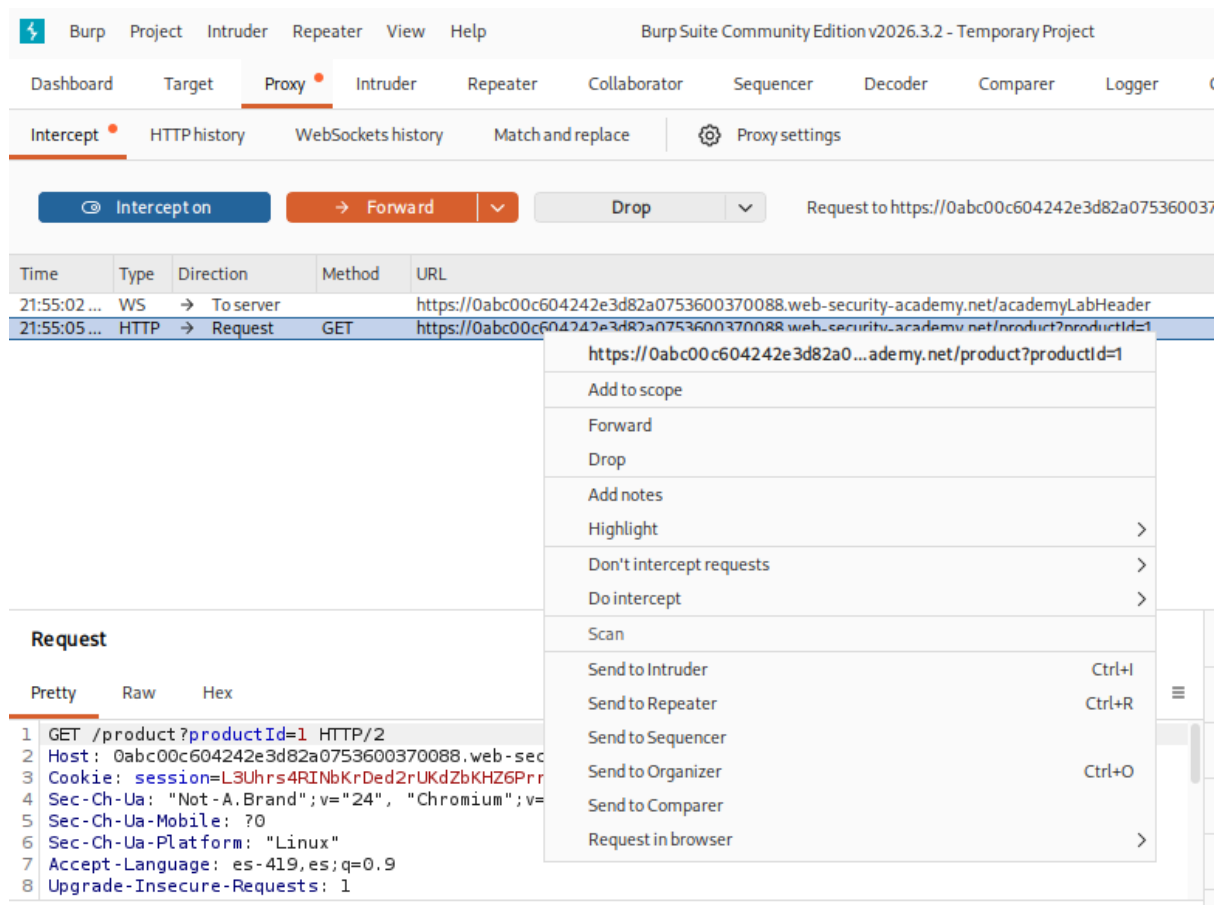
Beat the Vacation Traffic

★★★★★ \$18.44

[View details](#)

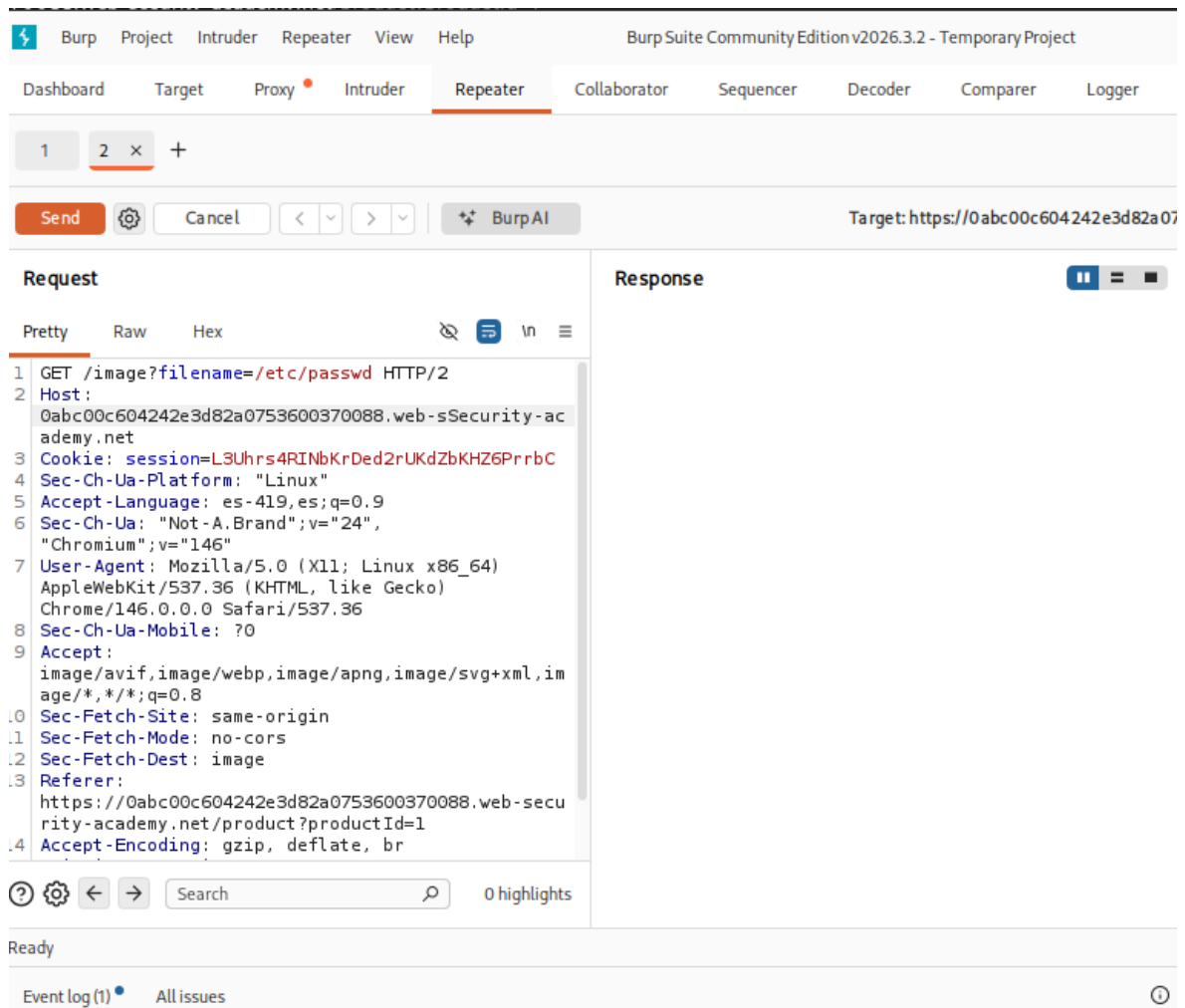
Se busca en el historial (pestaña Proxy > HTTP history) la petición que carga la imagen (GET /image?filename=...) y se selecciona con clic derecho → "Send to Repeater".

El módulo Repeater permite editar y reenviar la petición observando las respuestas del servidor en tiempo real.



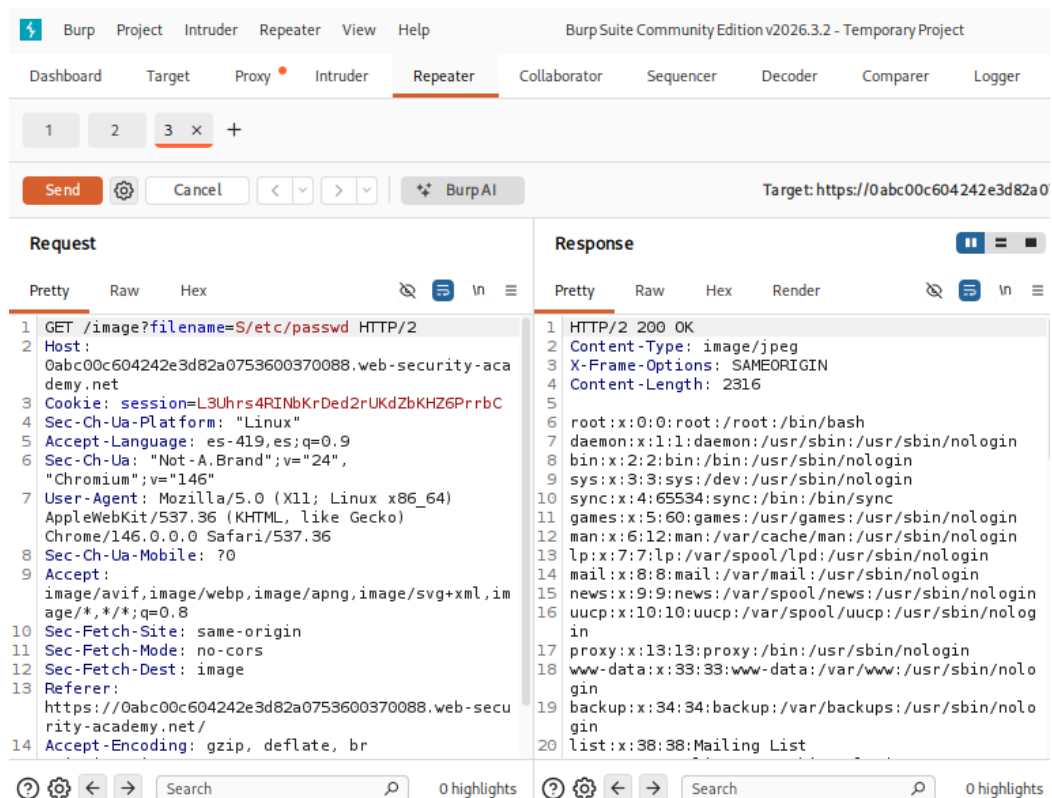
En la línea 1 del request, dentro de la pestaña Repeater, se modifica el valor del parámetro filename, reemplazando el nombre original de la imagen por la ruta absoluta maliciosa:

GET /image?filename=/etc/passwd HTTP/2



Se presiona "Send".

En el panel Response se observa una respuesta HTTP/2 200 OK con el contenido completo del archivo /etc/passwd del servidor:



Esto confirma que el filtro de secuencias de salto fue evadido exitosamente al proporcionar una ruta absoluta.

Se regresa a la pestaña del laboratorio en el navegador y se recarga la página (F5).

Apareció el banner verde: LAB Solved!

WebSecurity Academy

File path traversal, traversal sequences blocked with absolute path bypass

[Back to lab description >>](#)

LAB Solved

7. Explicación del payload

Payload utilizado: /etc/passwd

A diferencia del laboratorio de caso simple, en este payload no se utilizan secuencias de retroceso de directorio (../).

- / : El carácter inicial de barra diagonal le indica al sistema de archivos basado en Unix que la ruta proporcionada es absoluta. Es decir, le obliga a iniciar la búsqueda directamente desde la raíz del sistema operativo y no de forma relativa al directorio actual (/var/www/images/).
- etc/passwd : La ubicación estándar del archivo objetivo que contiene la lista de usuarios del sistema.

Al introducir la ruta absoluta completa, la validación de la aplicación no detecta ningún patrón de recorrido de directorios que deba bloquear. Acto seguido, la API del sistema de archivos ignora la ruta base predeterminada porque se le está dictando explícitamente desde dónde comenzar, permitiendo leer el archivo sin restricciones.

8. Mitigación recomendada

- No pasar la entrada del usuario directamente a las APIs del sistema de archivos. Es la medida más efectiva. En su lugar, se deben usar identificadores indirectos (como IDs numéricos en una base de datos) que el servidor asigne internamente a los archivos permitidos.
- Validación estricta con ruta canónica. Si es estrictamente necesario tomar la entrada del usuario, la aplicación debe resolver la ruta absoluta real del archivo (usando funciones como getCanonicalPath() en Java, o realpath() en PHP). Posteriormente, debe verificar de manera rigurosa que esta ruta canónica resultante comience exactamente con la ruta del directorio base permitido (ej. /var/www/images/).
- Lista blanca (Whitelist) de caracteres. Implementar validación de expresiones regulares que acepte únicamente nombres de archivo compuestos por caracteres alfanuméricos seguros y una extensión válida (ej. ^[a-zA-Z0-9_-]+\.[jpg\$]), rechazando categóricamente cualquier intento de enviar caracteres especiales como / o \.

